

Forensics — Timeline 0

Analyse d'image disque, création de MAC Timeline & Timestomping

PLATEFORME : picoCTF
2026

CATÉGORIE : Forensics
Disk

DIFFICULTÉ / AUTEUR : Medium / LT 'syreal'
Jones

FLAG : picoCTF{71m311n3_0u7113r_h3r_43a2e7af}

//# 1. OBJECTIF & RÉSUMÉ DE LA VULNÉRABILITÉ

L'objectif de ce challenge est d'analyser une image disque brute de partition (`partition4.img.gz`) afin de retrouver un flag dissimulé par un attaquant.

L'attaquant a utilisé la technique du **Timestomping** (altération intentionnelle des horodatages du système de fichiers) pour dissimuler un fichier suspect au sein d'une arborescence système classique. La création d'une chronologie globale des métadonnées (**MAC Timeline**) permet de faire ressortir ce fichier sous forme d'anomalie temporelle extrême (date remontant à 1985).

CONCEPT CLÉ CYBERSÉCURITÉ : TIMESTOMPING & MACB

Le **Timestomping** consiste à modifier les horodatages d'un fichier (Modified, Accessed, Changed, Birth) pour tromper l'analyse chronologique. Cependant, une modification superficielle laisse souvent des incohérences ou des dates artificiellement lointaines qui ressortent immédiatement lors de la génération d'une timeline globale via **The Sleuth Kit** (TSK).

//# 2. OUTILS & CONCEPTS CLÉS

Outil / Concept	Rôle & Utilisation dans le CTF
<code>gunzip</code>	Décompression de l'archive brute téléchargée <code>partition4.img.gz</code> vers l'image système <code>partition4.img</code> .
<code>fls</code> (Sleuth Kit)	Parcours récursif de l'image disque et extraction des métadonnées de tous les inodes pour générer un <i>bodyfile</i> .
<code>mactime</code> (Sleuth Kit)	Conversion du <i>bodyfile</i> en une chronologie lisible (Timeline) triée par date d'événement.
<code>icat</code> (Sleuth Kit)	Extraction directe du contenu binaire d'un fichier en ciblant son numéro d'inode, sans monter le système de fichiers.
Base64 & Leetspeak	Décodage du payload extrait de l'inode suspect et interprétation du texte leet (<code>71m311n3_0u7113r</code> = <i>Timeline Outlier</i>).

//# 3. DÉMARCHE PAS À PAS (MÉTHODOLOGIE)

Étape 1 : Décompression & Inspection Initiale

Téléchargement du fichier de challenge compressé, suivi de son extraction pour obtenir l'image de partition brute :

```
gunzip partition4.img.gz
```

Une première tentative d'analyse avec `exiftool` ou des recherches textuelles brutes (`strings | grep`) échoue. En effet, le contenu recherché est encodé et masqué dans la structure profonde des inodes du système de fichiers.

Étape 2 : Génération de la MAC Timeline (The Sleuth Kit)

En s'appuyant sur l'indice N°1 ("*Create a Sleuthkit MAC timeline!*"), l'objectif est d'extraire toutes les métadonnées de la partition à l'aide de `fls` (avec l'option récursive `-r`) pour construire un **bodyfile**, puis de le formater avec `mactime` :

1. Génération du bodyfile :

```
fls -r -m "/" partition4.img > bodyfile.txt
```

2. Conversion en timeline structurée :

```
mactime -b bodyfile.txt -d -y -z Europe/Paris > timeline.csv
```

Étape 3 : Détection de l'Anomalie Temporelle (Timestomping)

En examinant le fichier `timeline.csv` généré (conformément à l'indice N°2 : "*Sloppy timestomping can yield strange (very old) timestamps*"), une ligne isolée ressort immédiatement parmi l'ensemble des fichiers datant de 2025/2026 :

```
1985-01-01T17:00:00Z,41,macb,r/rrw-r--r--,0,0,4945,"/bin/bcab"
```

L'analyse des métadonnées révèle :

- **Horodatage anormal** : 1er Janvier 1985.
- **Emplacement suspect** : Fichier `/bin/bcab`.
- **Inode associé** : Numéro `4945`.

Étape 4 : Extraction du Contenu via Inode & Décodage

Plutôt que de monter la partition, nous utilisons l'outil `icat` pour extraire directement la charge utile associée à l'inode `4945` :

```
icat partition4.img 4945  
# Sortie brute : NzFtMzExbjNfMHU3MTEzc19oM3JfNDNhMmU3YWYK
```

La chaîne obtenue est encodée en **Base64**. Nous procédons au décodage directement en ligne de commande :

```
echo "NzFtMzExbjNfMHU3MTEzc19oM3JfNDNhMmU3YWYK" | base64 -d  
# Sortie décodée : 71m311n3_0u7113r_h3r_43a2e7af
```

Le texte obtenu est en *leetspeak* : `71m311n3` (Timeline), `0u7113r` (Outlier / Anomalie). En encapsulant la chaîne dans le format picoCTF requis, nous validons le flag :

```
picoCTF{71m311n3_0u7113r_h3r_43a2e7af}
```

//# 4. MÉMENTO TECHNIQUE (CHEATSHEET SLEUTH KIT)

Commandes TSK (The Sleuth Kit) incontournables :

Commande TSK	Description & Rôle Forensics
<code>fls -r -m "/" </code>	Liste de manière récursive (<code>-r</code>) les fichiers et répertoires d'une image disque en attribuant le préfixe de chemin racine (<code>-m "/"</code>) pour produire un <i>bodyfile</i> .
<code>mactime -b <bodyfile></code>	

Commande TSK	Description & Rôle Forensics
	Analyse un <i>bodyfile</i> pour créer un rapport chronologique lisible des modifications (M), accès (A), changements de métadonnées (C) et créations (B).
<code>icat <inode></code>	Extrait le contenu binaire brut d'un fichier spécifié par son numéro d'inode, contournant les restrictions de montage du système de fichiers.
<code>ils </code>	Affiche les informations relatives aux inodes (notamment les inodes supprimés ou orphelins).

//# 5. LEÇONS RETENUES & REFLEXES À GARDER

AUTOMATISMES FORENSICS SYSTÈME DE FICHIERS

- **Recherche ciblée vs Globale** : Ne pas se limiter à `strings` ou `exiftool` lorsque l'attaquant a pu encoder des données ou modifier la structure du système de fichiers.
- **L'Analyse Temporelle (Timelining)** : Face à un système de fichiers volumineux, la génération d'une MAC Timeline est le meilleur moyen d'isoler rapidement les anomalies (fichiers modifiés récemment, ou dates artificielles comme 1980/1985).
- **Extraction par Inode (`icat`)** : Garder le réflexe d'extraire les objets suspects directement avec `icat <image> <inode>` . Cela évite d'altérer la preuve en montant la partition en écriture.
- **Compréhension du Leetspeak** : Dans les CTF, les flags décodés contiennent souvent du texte leet en lien direct avec le thème du challenge (ex: `71m311n3_0u7113r` = *timeline outlier*).